

=====

BUMPASS FIRE & RESCUE
REPLAY-RESISTANT AUTHENTICATION POLICY

=====

Document ID: POL-IA-004
Version: 1.0
Effective Date: April 15, 2026
Review Date: April 15, 2027
Owner: Mike Sadler, IT Administrator
Approved By: Chief Randy Bowles

=====

1. PURPOSE

This policy requires that authentication mechanisms used to access BFR systems are resistant to replay attacks, where captured authentication credentials cannot be reused.

2. REPLAY-RESISTANT MECHANISMS REQUIRED

2.1 Domain Authentication

- Kerberos v5 is used for domain authentication (replay resistant by design - uses time-stamped tickets and nonces; tickets expire in 10 hours)
- NTLM authentication is disabled where possible (legacy only for backward compatibility with specific apps)

2.2 Azure AD / Cloud Authentication

- OAuth 2.0 with PKCE and short-lived access tokens (access tokens expire in 1 hour)
- Refresh tokens are single-use (rotated on use)
- MFA one-time push notification codes (not reusable)

2.3 VPN Authentication

- IKEv2 with certificate-based mutual authentication (nonce exchange prevents replay)
- SAML assertions include NotOnOrAfter timestamps (5-minute validity window - replay rejected by IdP)

2.4 Remote Desktop

- NLA (Network Level Authentication) with Kerberos tickets
- Credential Guard enabled to prevent pass-the-hash

3. PROHIBITED METHODS

- Basic authentication (username/password in HTTP header) is disabled on all BFR systems
- Legacy NTLM v1: prohibited
- Simple password-over-HTTP forms: not used

=====

Approved: Chief Randy Bowles 04/15/2026
Prepared: Mike Sadler 04/12/2026

=====